Informe final

1. Introducción

El problema abordado en este laboratorio fue la privacidad de los datos y que se debe de tomar en cuenta al eliminarlos y la función de cada uno

2. Inventario de datos

Nombre: dato personal de identificación.

Correo electrónico: dato personal de contacto.

Teléfono: dato personal de contacto.

RFC: dato personal utilizado para fines fiscales.

Edad: dato personal.

Ciudad: dato personal de ubicación general.

Código postal: dato personal de ubicación.

3. Finalidades

Los datos deben utilizarse únicamente para finalidades específicas y documentadas, cada dato debe tener una finalidad clara antes de ser recopilado.

El nombre permite identificar al cliente. El correo electrónico y el teléfono permiten mantener comunicación con él. El RFC se utiliza para procesos de facturación. La edad puede utilizarse para validar requisitos o generar estadísticas. La ciudad y el código postal pueden utilizarse para análisis geográficos y para envíos.

4. Minimización

La edad puede sustituirse por rangos de edad cuando el objetivo es realizar análisis estadísticos. El código postal puede generalizarse a nivel regional cuando no se requiere precisión. El RFC solo debe solicitarse cuando exista una necesidad de facturación. Los analistas no necesitan acceder a nombres, correos electrónicos ni teléfonos para generar estadísticas.

5. Control de acceso

El personal de atención al cliente debe acceder únicamente a la información necesaria para atender a los clientes. El área de facturación debe acceder a los datos relacionados con los procesos fiscales. El personal de analítica debe trabajar con datos anonimizados o agregados. El DBA debe administrar la infraestructura y los mecanismos de seguridad sin utilizar la información para finalidades de negocio. El personal de auditoría debe revisar registros y evidencias de actividad.

6. Derechos ARCO

La organización debe ser capaz de localizar, modificar, corregir, eliminar o restringir el uso de los datos personales cuando corresponda.

Para ello es necesario identificar dónde se almacenan los datos, qué sistemas contienen información relacionada, quién tiene acceso a ella y qué copias existen en respaldos o entornos alternos.

7. Retención

El periodo de conservación debe definirse considerando la finalidad del tratamiento, las necesidades operativas y los riesgos asociados al almacenamiento prolongado.

Los datos no deben conservarse indefinidamente. Cuando la finalidad desaparezca la organización debe eliminar, anonimizar o archivar la información según corresponda.

8. Gobierno de datos

El propietario de los datos debe definir la finalidad y los usos autorizados.

El DBA debe administrar la infraestructura, la disponibilidad, los respaldos y los controles técnicos.

El área de seguridad debe implementar medidas de protección y monitoreo.

El área de auditoría debe verificar el cumplimiento de las políticas y procedimientos establecidos.

9. Evaluación integral

Que los datos se queden demasiado tiempo en el sistema o que los datos puedan ser usados por personal que no requiera los datos y que no se apliquen medidas básicas para la seguridad de los datos

10. Conclusiones

Una base de datos segura no garantiza necesariamente el cumplimiento de los principios de privacidad. La recopilación mínima de datos, la definición clara de finalidades, el control de acceso adecuado y la retención limitada son elementos fundamentales para proteger la información personal.

Preguntas de reflexión

1. ¿Una base de datos técnicamente segura necesariamente cumple con todos los requisitos de privacidad?

No. Una base de datos puede estar protegida contra ataques y aun así recopilar datos innecesarios.

2. ¿Por qué el principio de mínimo privilegio también contribuye a la privacidad?

Porque limita el acceso a los datos únicamente a las personas que realmente los necesitan para realizar sus funciones.

3. ¿Por qué el DBA no debería decidir por sí solo la finalidad del tratamiento de los datos?

Porque la finalidad debe ser definida por las diferentes áreas considerando el uso que se les va a dar a cada dato que se requiera.

4. ¿Por qué los desarrolladores no deberían recibir automáticamente copias completas de bases de datos productivas?

Porque podrían acceder a información personal innecesaria para realizar sus actividades de desarrollo.

5. ¿Por qué una copia utilizada para desarrollo también puede representar un riesgo de privacidad?

Porque contiene datos personales que podrían quedar expuestos en un entorno con menos controles de seguridad.

6. ¿Por qué la retención debe formar parte del ciclo de vida de los datos?

Porque los datos deben eliminarse o anonimizarse cuando dejan de ser necesarios para su finalidad.

7. ¿Qué relación existe entre privacidad por diseño y diseño de bases de datos?

La privacidad por diseño implica incorporar controles de protección, minimización y acceso desde la etapa de diseño de la base de datos.

8. ¿Qué controles técnicos implementarías para reducir el riesgo de exposición de datos personales?

Implementaría control de acceso basado en roles, cifrado de datos, auditoría de accesos, anonimización, seudonimización y segmentación de ambientes.

9. ¿Qué información debería conocer un DBA para responder técnicamente a una solicitud ARCO?

Debe conocer la ubicación de los datos, las tablas involucradas, las relaciones existentes, los respaldos disponibles y los procedimientos de actualización o eliminación.

10. ¿Qué responsabilidades deberían corresponder al DBA, al responsable de privacidad, al área jurídica y al propietario de los datos?

El DBA debe administrar la infraestructura y los controles técnicos. El responsable de privacidad debe supervisar el cumplimiento de las normas de protección de datos. El área jurídica debe proporcionar orientación legal y regulatoria. El propietario de los datos debe definir las finalidades, usos autorizados y periodos de conservación.